🌐 Module 05: Web Application Penetration Testing

```
# Exercise 14: Performing a Local File Inclusion (LFI) Attack
```

Scenario

Local File Inclusion (LFI) vulnerability occurs when a web application dynamically incorporates local files into page execution without proper validation or sanitization of user-supplied input. This allows an attacker to manipulate file path parameters (such as `language` or `page`) to read sensitive system configuration files (e.g., `/etc/passwd`, database credentials, or application source code) hosted on the web server.

In this exercise, we deploy the **bWAPP** (buggy Web Application) container on Ubuntu and exploit an LFI vulnerability from Parrot Security to extract the target system's `/etc/passwd` file.

Objective

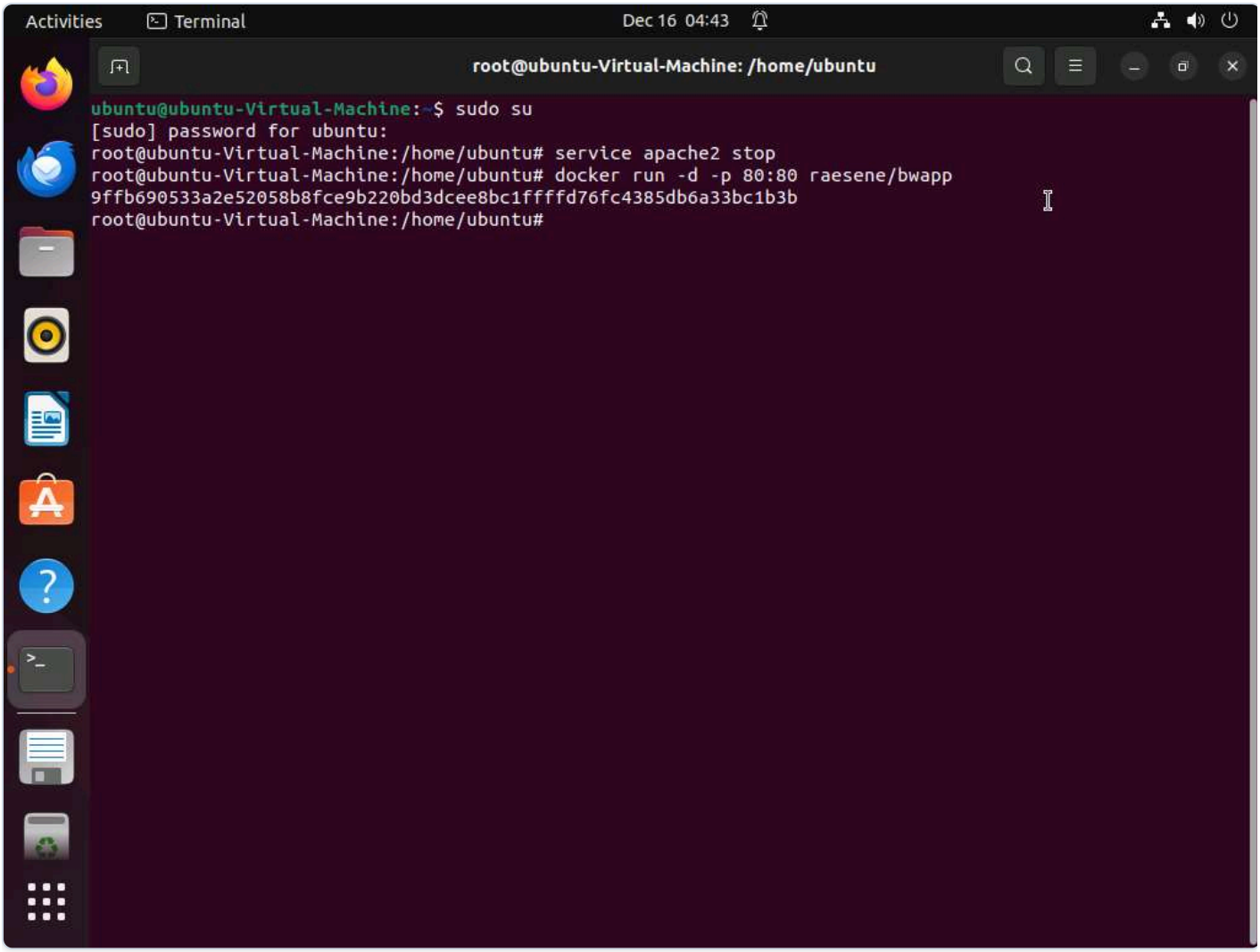
The objective of this lab is to help students learn how to:
- Deploy and initialize the bWAPP vulnerable web application using Docker
- Identify unvalidated parameter queries in Remote & Local File Inclusion (RFI/LFI) modules
- Execute Local File Inclusion (LFI) attacks via direct URL parameter manipulation to extract sensitive Linux system files (`/etc/passwd`)

Task 1: Performing a Local File Inclusion (LFI) Attack

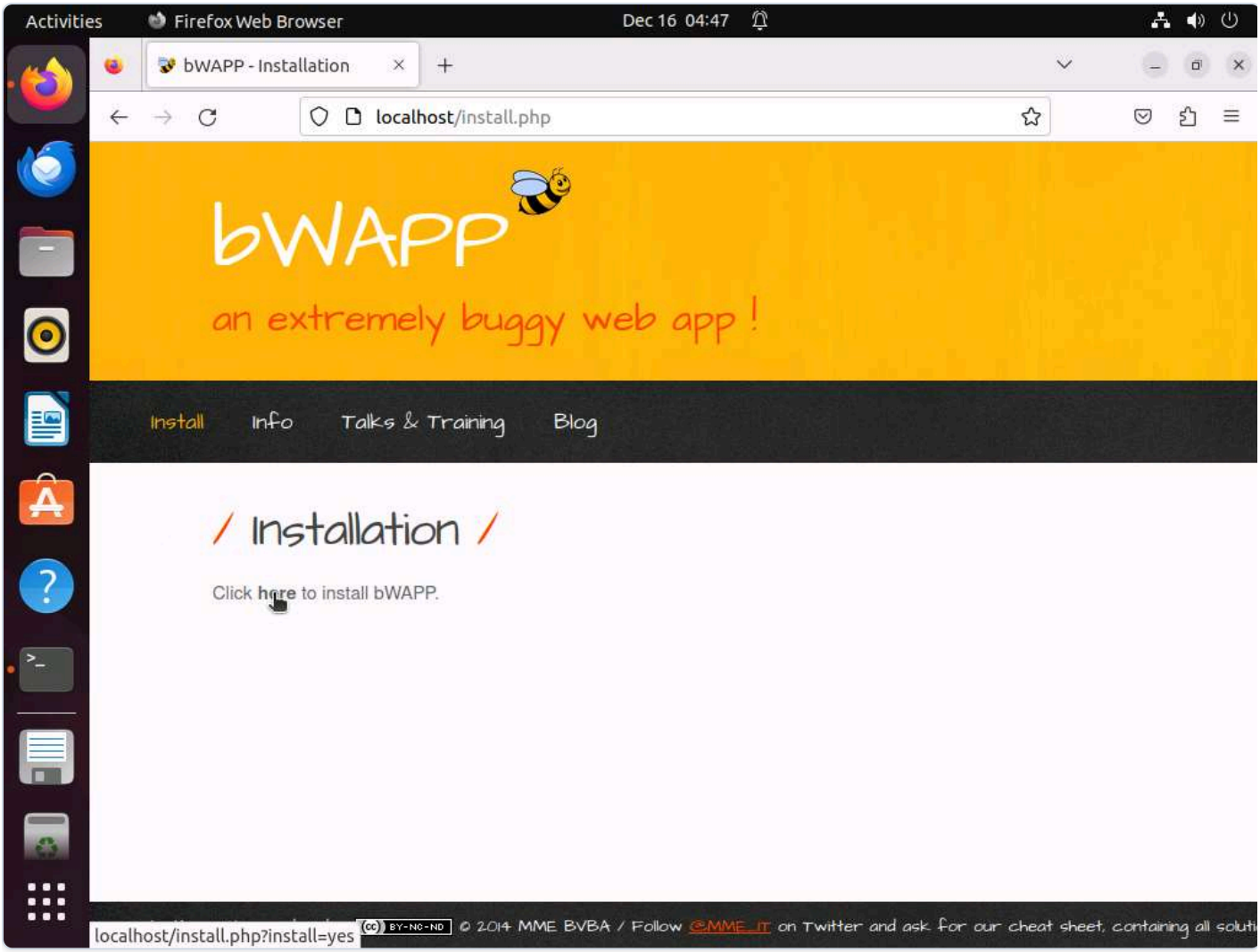
In this task, we stop Apache and launch the `raesene/bwapp` Docker container on the Ubuntu host, complete bWAPP database initialization, navigate to the RFI/LFI module from Parrot Security (`http://192.168.0.19/rlfi.php`), and manipulate the `language` parameter to read `/etc/passwd`.

Lab Tasks

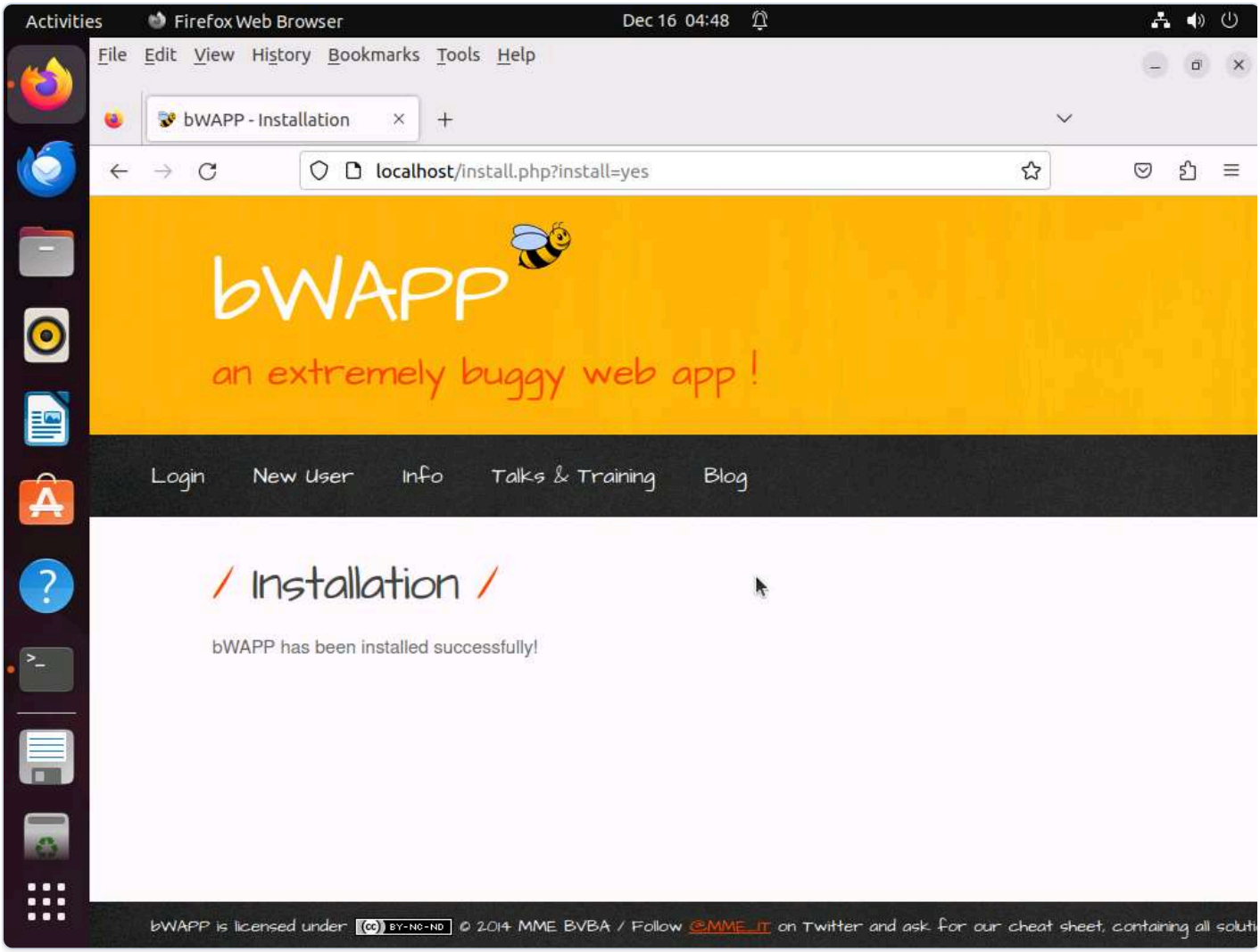
1. Switch to the **Ubuntu** machine, type **toor** in the Password field, and press Enter.
2. Open a terminal with sudo privileges and execute:
   sudo service apache2 stop && sudo docker run -d -p 80:80 raesene/bwapp



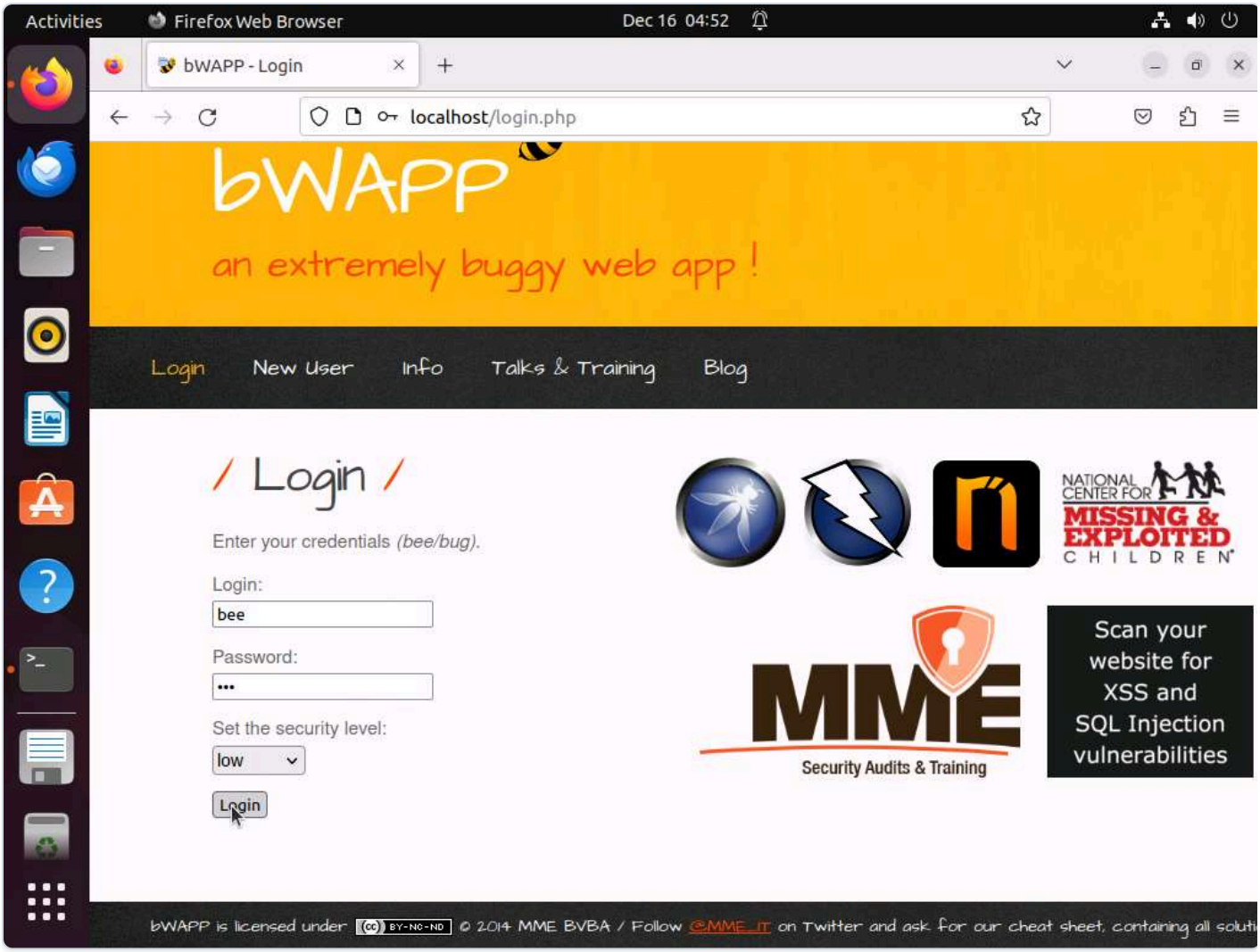
1. Open a browser on Ubuntu, navigate to **http://localhost/install.php**, and click the **here** link under installation to create/reset the bWAPP database.



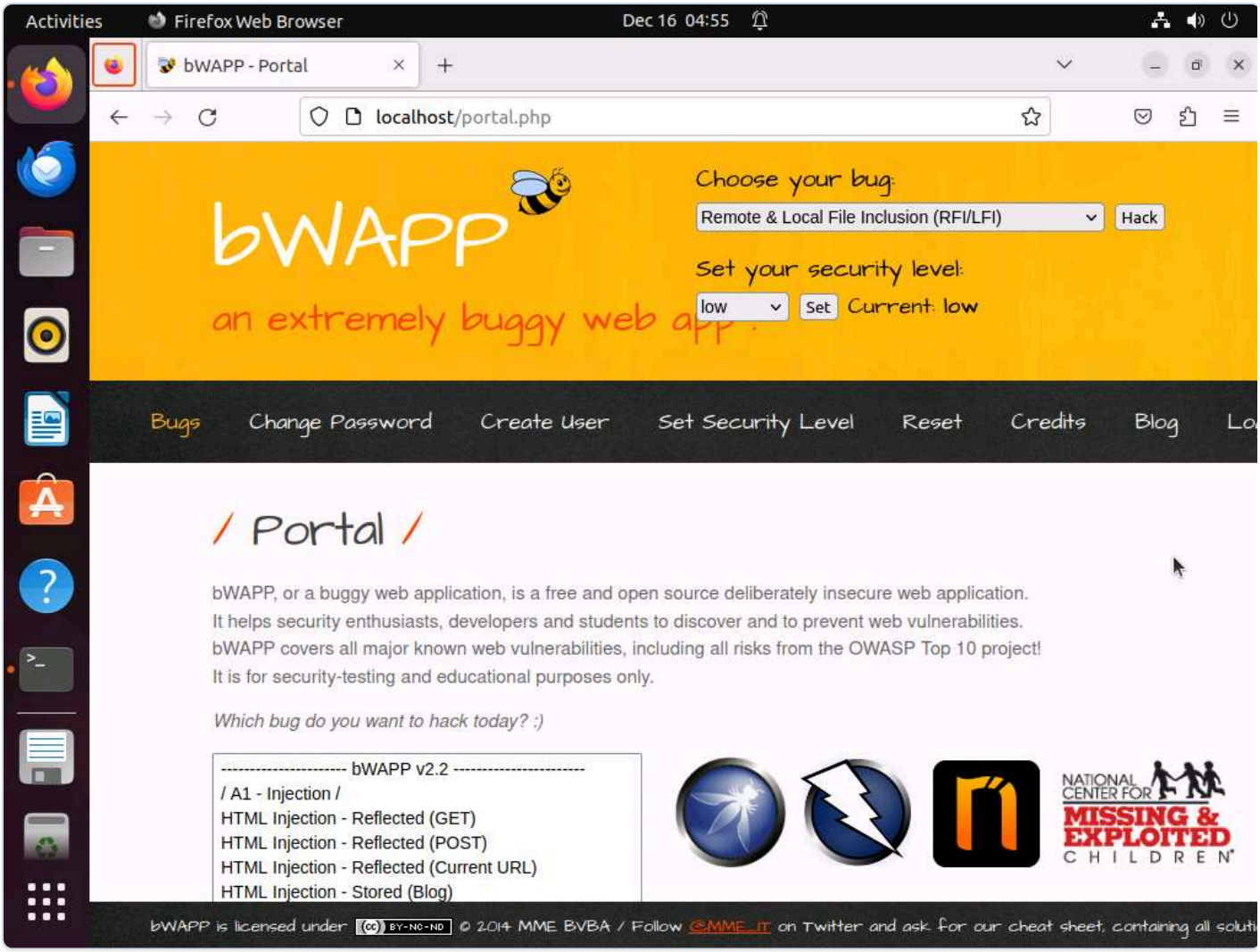
1. Confirm successful installation ("*bWAPP has been installed successfully!*"). Note the bWAPP version displayed on the setup page: **2.2**.



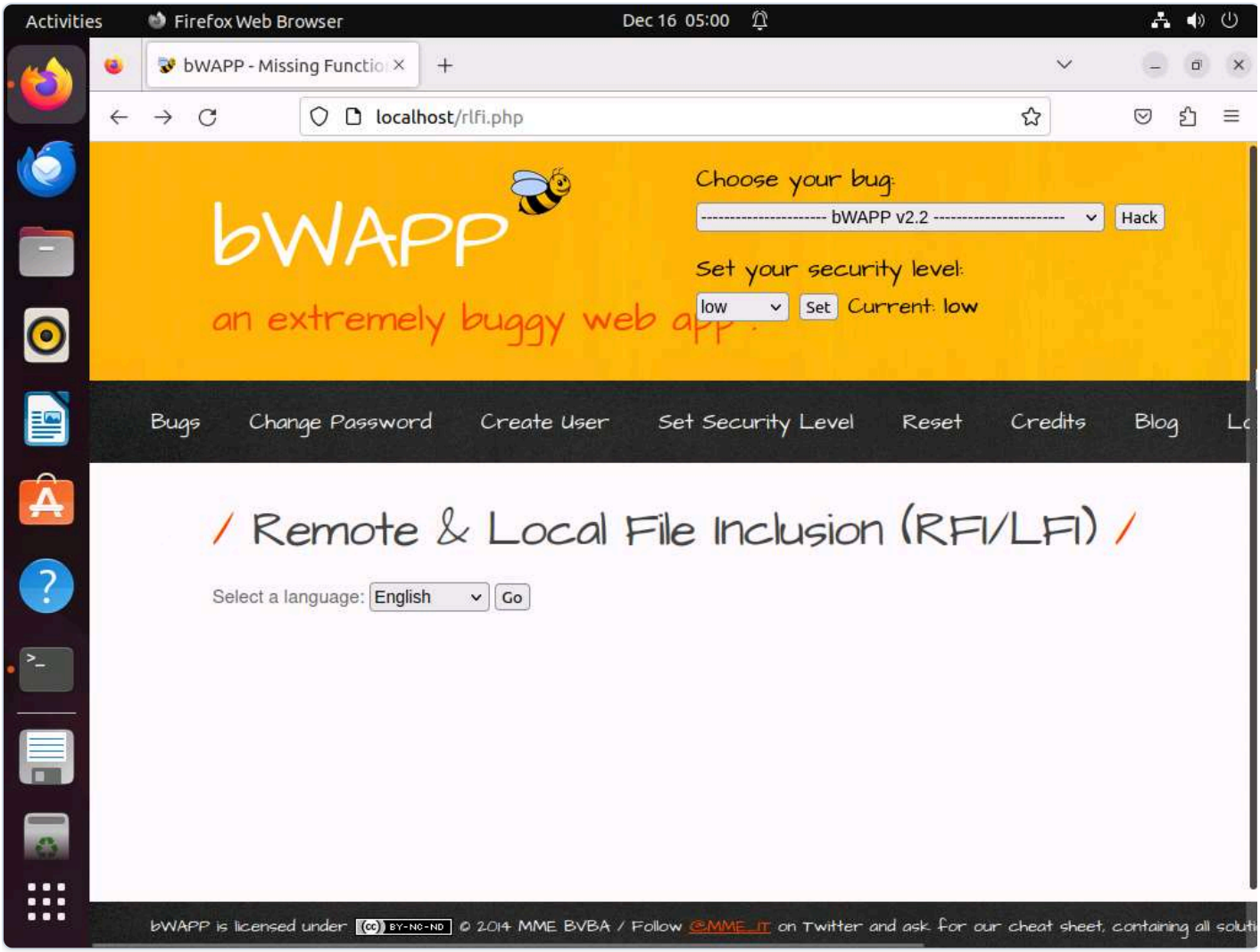
1. Click **Login** and log in with default bWAPP credentials:
2. Username: **bee**
3. Password: **bug**



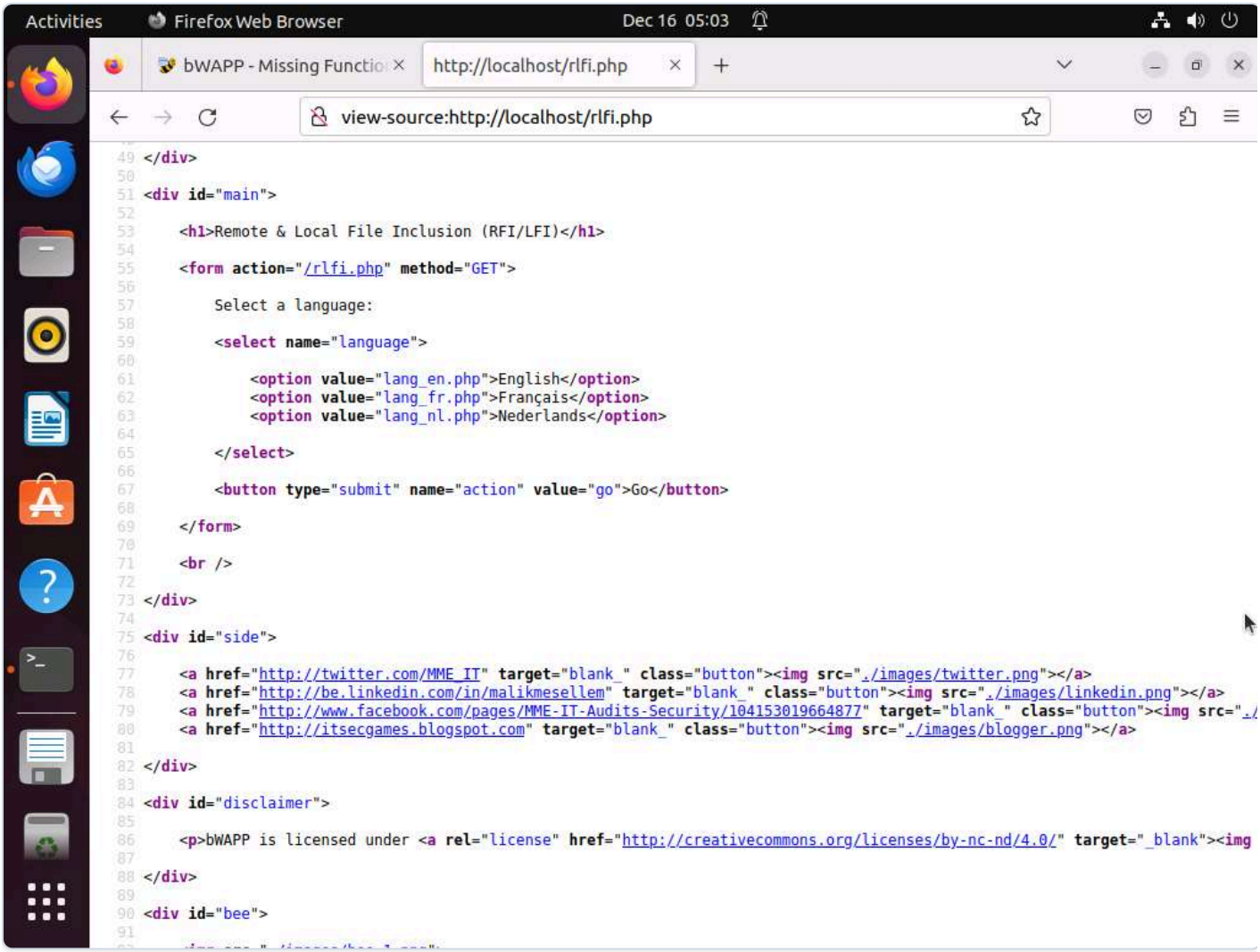
1. Under **Choose your bug**, select **Remote & Local File Inclusion (RFI/LFI)** from the drop-down list and click **Hack**.



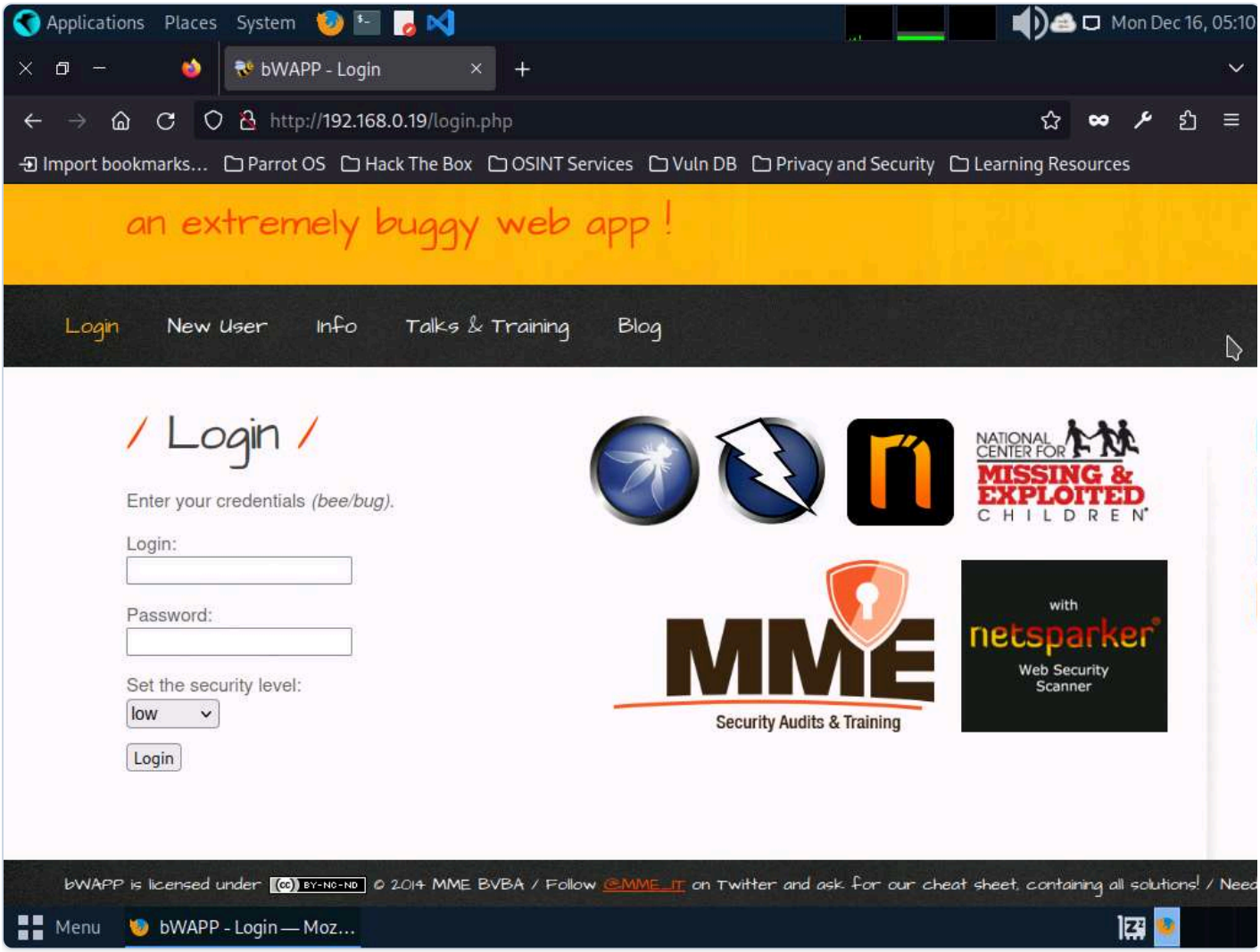
1. The RFI/LFI challenge page opens (`rlfi.php`).



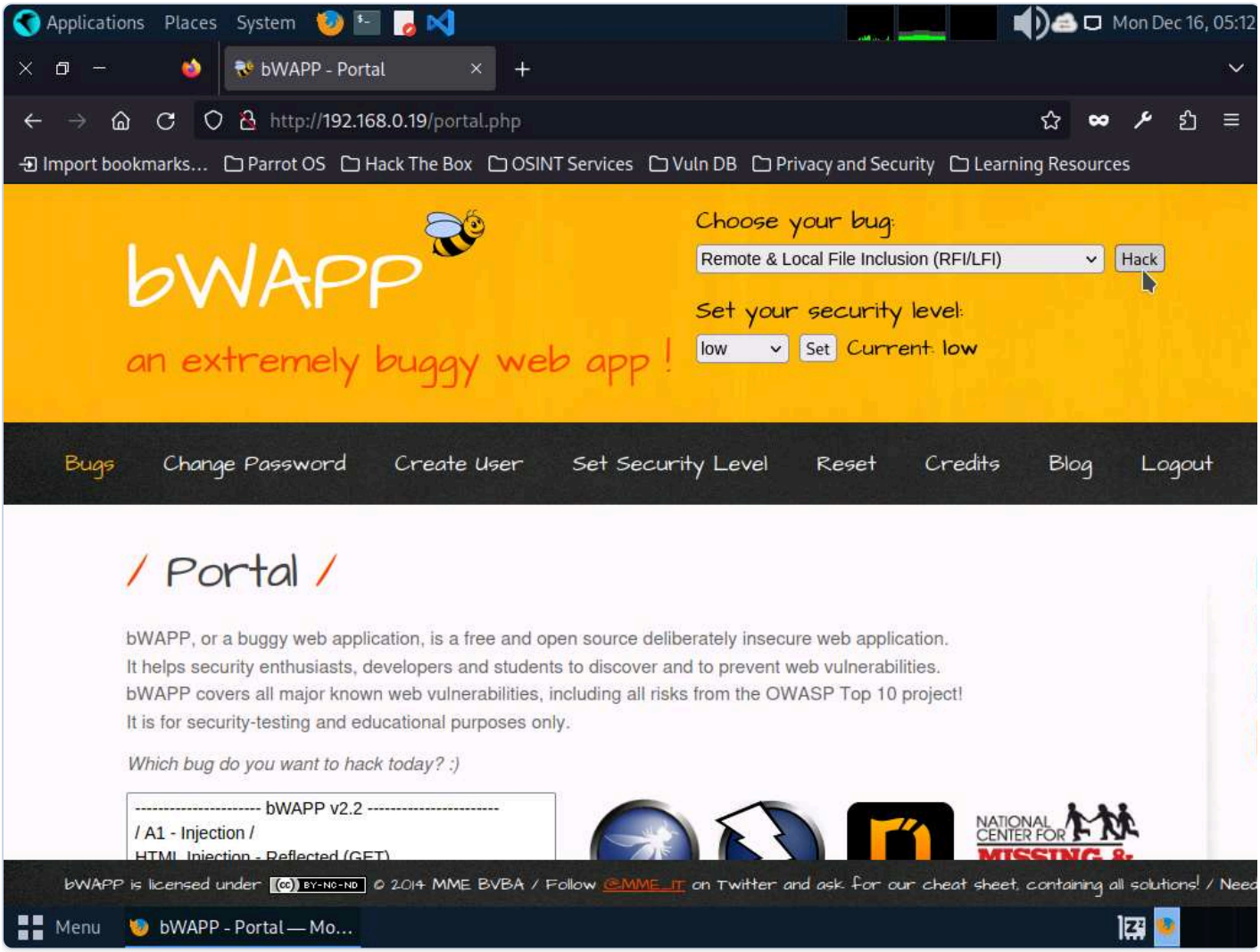
1. Inspect the page source by navigating to `view-source:http://localhost/rlfi.php` or using Developer Tools to review parameter handling.



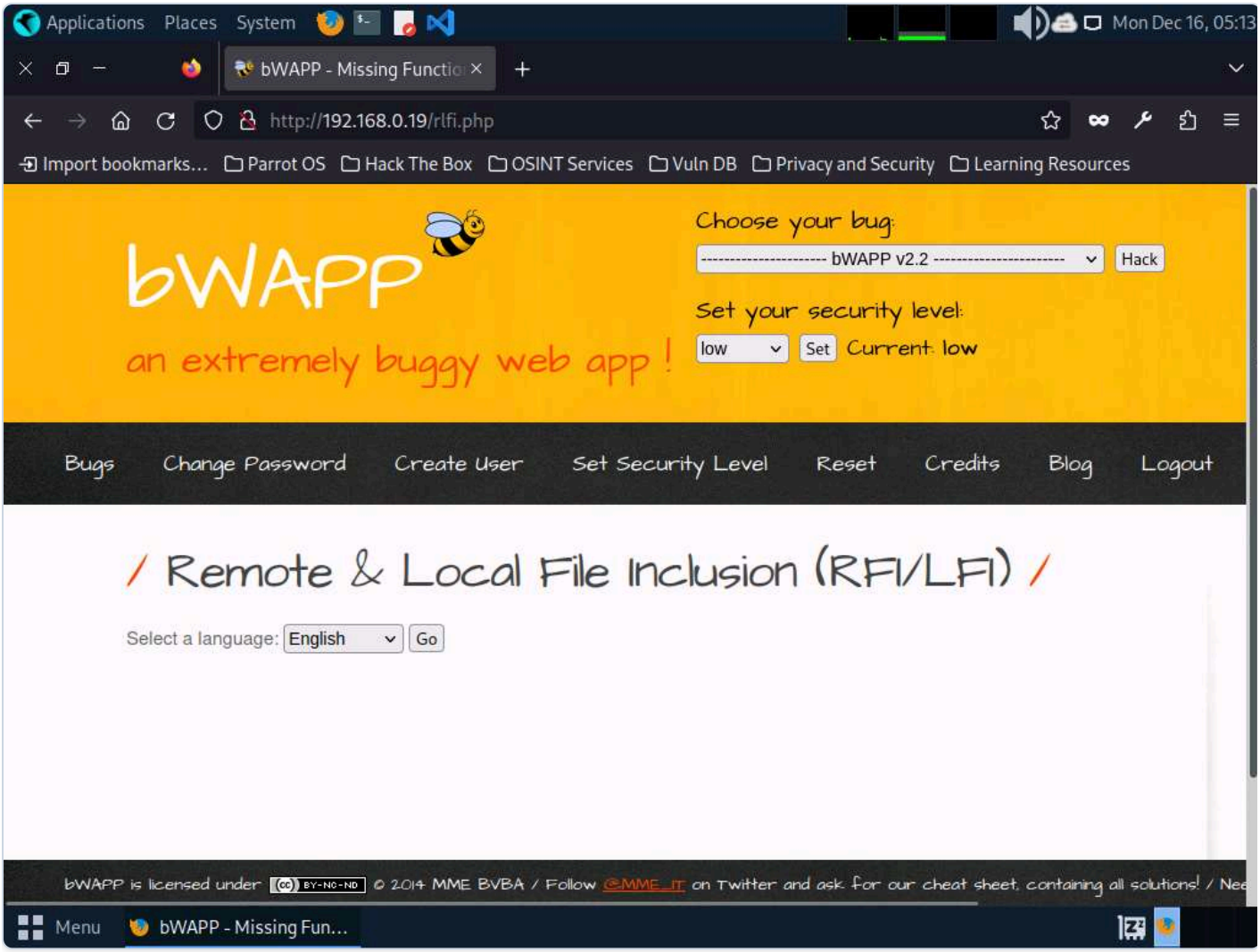
1. Switch to the **Parrot Security** machine, log in with **pentester** / **toor**, and open Firefox.
2. Navigate to **http://192.168.0.19** and log in with **bee** / **bug**.



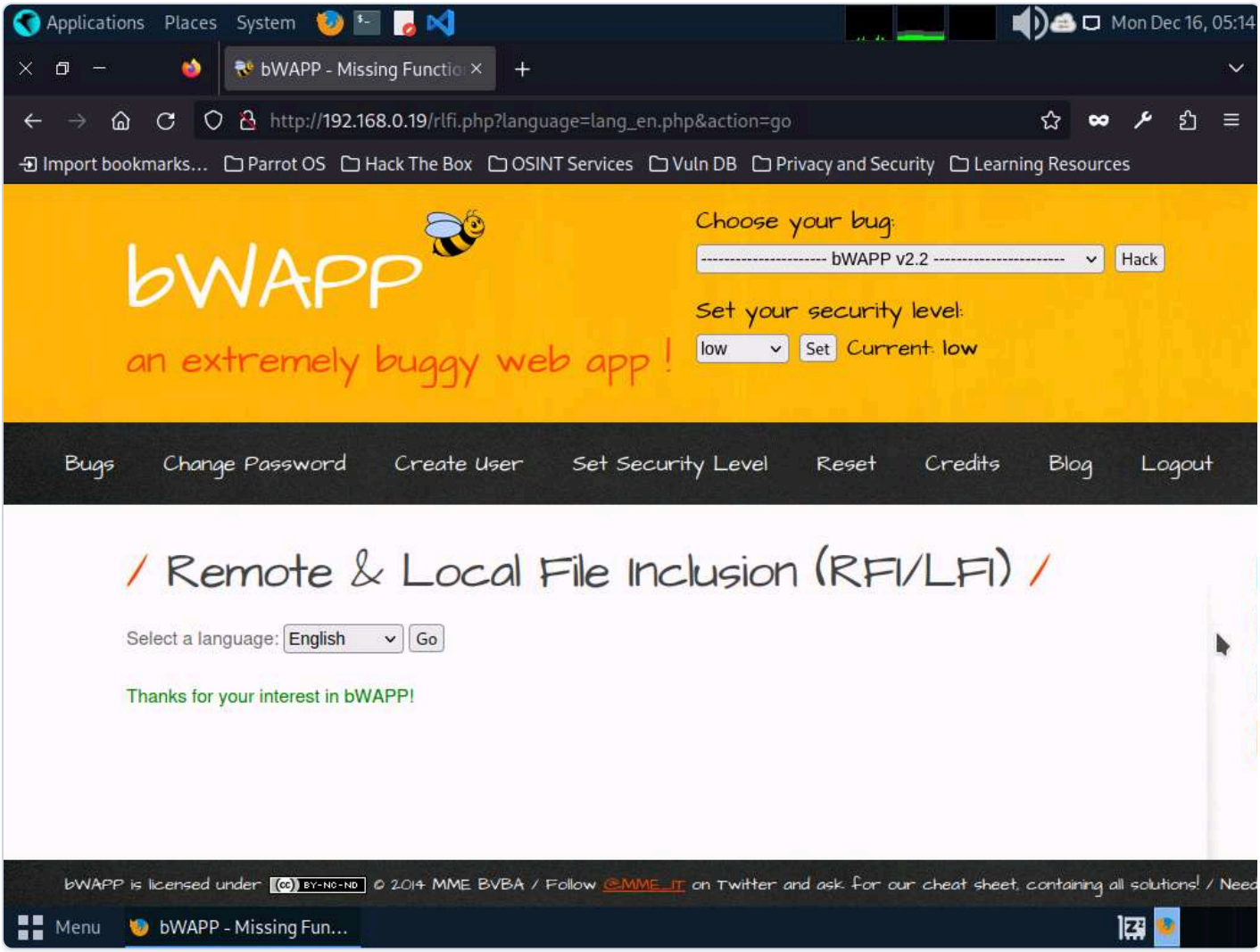
1. Under **Choose your bug**, select **Remote & Local File Inclusion (RFI/LFI)** and click **Hack**.



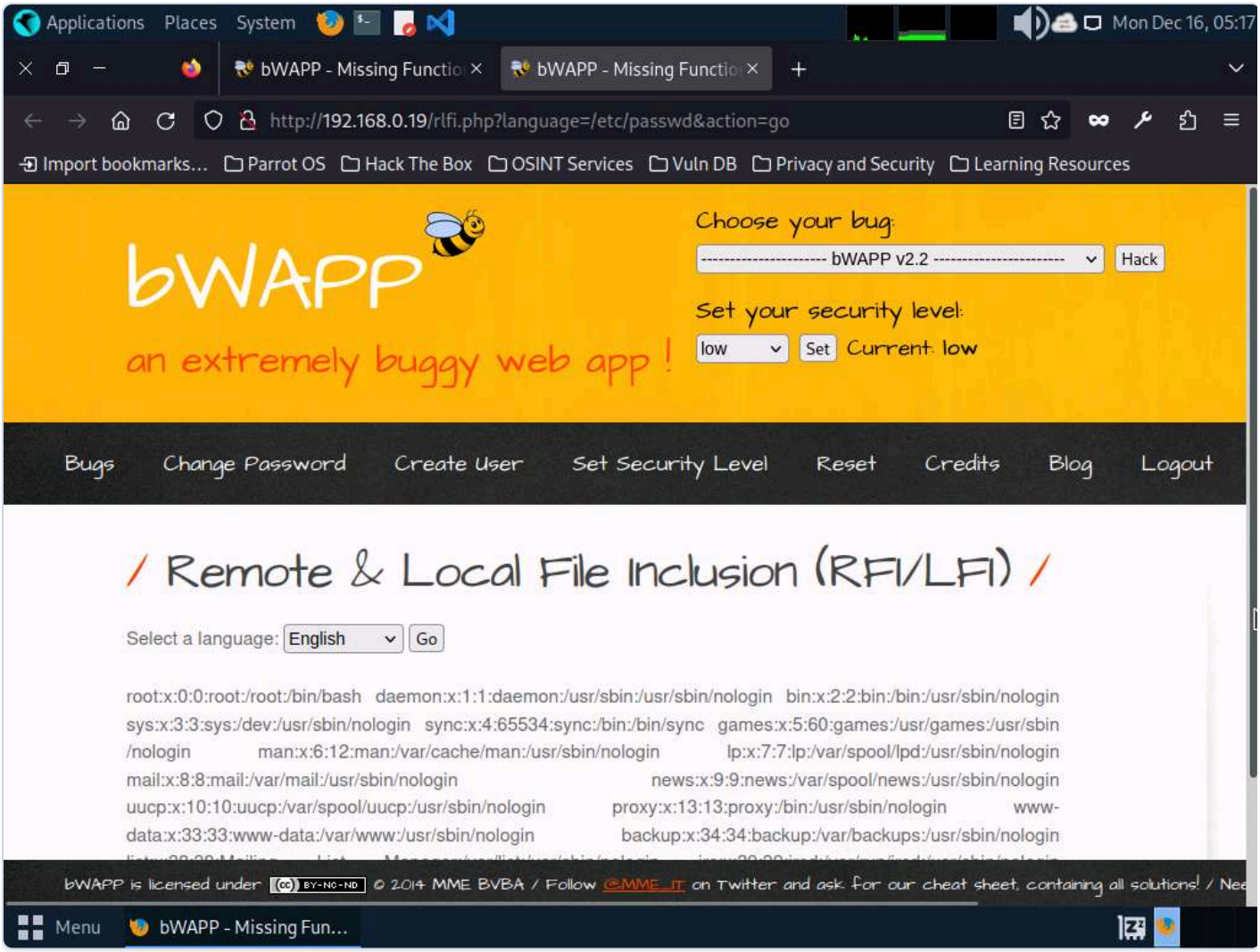
1. Observe the URL parameter query structure in the browser address bar (`language=lang_en.php`).



1. Test for unvalidated Local File Inclusion by directly replacing the `language` parameter value with **/etc/passwd** in a new tab:
   http://192.168.0.19/rlfi.php?language=/etc/passwd&action=go



1. Press Enter. The web server renders the unparsed contents of **/etc/passwd** directly inside the web page, confirming successful LFI exploitation.



1. Leave bWAPP running for the next exercise.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.14.1.1** On the Ubuntu machine, launch the bWAPP web application. Using the Parrot Security machine, simulate and analyze Local File Inclusion (LFI) vulnerabilities. Document the version of bWAPP utilized in this lab. [!SUCCESS] ✅ **Answer:** **2.2**